



# Cyberscope

A *TAC Security* Company

## Source Code Review Report

# **The First Lady**

May 2026

Audited by © cyberscope

# Table of Contents

|                                                   |           |
|---------------------------------------------------|-----------|
| <b>Table of Contents</b>                          | <b>1</b>  |
| <b>Risk Classification</b>                        | <b>2</b>  |
| <b>Review</b>                                     | <b>3</b>  |
| Audit Updates                                     | 3         |
| <b>Overview</b>                                   | <b>4</b>  |
| Source Code Review Scope                          | 4         |
| <b>Findings Breakdown</b>                         | <b>5</b>  |
| <b>Diagnostics</b>                                | <b>6</b>  |
| HAWCE- Hardcoded Admin Wallet Credentials Exposed | 7         |
| Description                                       | 7         |
| Recommendation                                    | 8         |
| OCI - Outdated Components Implemented             | 9         |
| Description                                       | 9         |
| Recommendation                                    | 13        |
| CHM - CSP Header Misconfigured                    | 14        |
| Description                                       | 14        |
| Recommendation                                    | 15        |
|                                                   | 15        |
| <b>Summary</b>                                    | <b>15</b> |
| <b>Disclaimer</b>                                 | <b>16</b> |
| <b>About Cyberscope</b>                           | <b>18</b> |

# Risk Classification

The criticality of findings in Cyberscope's smart contract audits is determined by evaluating multiple variables. The two primary variables are:

1. **Likelihood of Exploitation:** This considers how easily an attack can be executed, including the economic feasibility for an attacker.
2. **Impact of Exploitation:** This assesses the potential consequences of an attack, particularly in terms of the loss of funds or disruption to the contract's functionality.

Based on these variables, findings are categorized into the following severity levels:

1. **Critical:** Indicates a vulnerability that is both highly likely to be exploited and can result in significant fund loss or severe disruption. Immediate action is required to address these issues.
2. **Medium:** Refers to vulnerabilities that are either less likely to be exploited or would have a moderate impact if exploited. These issues should be addressed in due course to ensure overall contract security.
3. **Minor:** Involves vulnerabilities that are unlikely to be exploited and would have a minor impact. These findings should still be considered for resolution to maintain best practices in security.
4. **Informative:** Points out potential improvements or informational notes that do not pose an immediate risk. Addressing these can enhance the overall quality and robustness of the contract.

| Severity              | Likelihood / Impact of Exploitation                      |
|-----------------------|----------------------------------------------------------|
| ● Critical            | Highly Likely / High Impact                              |
| ● Medium              | Less Likely / High Impact or Highly Likely/ Lower Impact |
| ● Minor / Informative | Unlikely / Low to no Impact                              |

# Review

|               |                   |
|---------------|-------------------|
| <b>Source</b> | Source Code Files |
|---------------|-------------------|

## Audit Updates

|                          |                                   |
|--------------------------|-----------------------------------|
| <b>Initial Audit</b>     | 08 January 2026 - 19 January 2025 |
| <b>Revalidated Audit</b> | 18 March 2026 - 19 March 2026     |
| <b>Revalidated Audit</b> | 11 May 2026                       |
| <b>Revalidated Audit</b> | 14 May 2026                       |

## Overview

Cyberscope has conducted a comprehensive Source Code Review for “Ladycafe”. The source code review was performed using a manual, risk-based approach, supplemented by automated analysis where appropriate. The assessment focused on security-critical components and high-risk code paths, including authentication mechanisms, sensitive data handling, external integrations, and business logic. The review began with an architectural understanding of the application, followed by systematic examination of source files to identify potential vulnerabilities, insecure API usage, hardcoded secrets, and improper error or logging practices. Findings were validated through contextual analysis to reduce false positives and assess real-world exploitability. All identified issues were documented with clear descriptions, risk ratings, and remediation recommendations based on secure coding guidelines and applicable security standards.

With the expansion of blockchain technology and related integrations, source code review is a structured security assessment technique used to identify vulnerabilities, insecure coding practices, and logic flaws directly within an application’s source code. Unlike black-box testing, source code review provides full visibility into the application’s implementation, enabling the detection of security weaknesses that may not be observable during runtime testing. This approach is particularly effective for identifying issues related to authentication, authorization, data storage, cryptography, input validation, and error handling. The review is conducted in alignment with industry-recognized standards and best practices to ensure the application meets established security requirements.

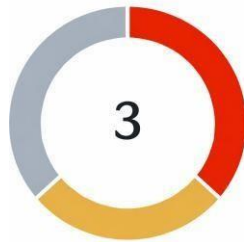
## Source Code Review Scope

The scope of this assessment focused on identifying security vulnerabilities and weaknesses within the application's source code and overall implementation, with the objective of providing actionable recommendations to improve its security posture. The review examined relevant portions of the codebase, with emphasis on security-critical components, including authentication and authorization logic, sensitive data handling, cryptographic implementations, input validation and output encoding, error handling, logging practices, and interaction with external services and dependencies.

Particular attention was given to common software security risks and insecure coding patterns referenced in industry standards such as OWASP Top 10, OWASP Mobile/Web Security Guidelines, and CWE, including hardcoded secrets, improper access control enforcement, insecure deserialization, injection vulnerabilities, security misconfigurations, and inadequate protection of sensitive information.

This report aims to provide a comprehensive understanding of the application's code-level security strengths and areas for improvement, enabling informed decisions to remediate identified issues, reduce attack surface, and enhance the overall security resilience of the application.

## Findings Breakdown



- Critical 1
- Medium 1
- Minor / Informative 1

| Severity              | Unresolved | Acknowledged | Resolved | Other |
|-----------------------|------------|--------------|----------|-------|
| ● Critical            | 0          | 0            | 1        | 0     |
| ● Medium              | 0          | 0            | 1        | 0     |
| ● Minor / Informative | 0          | 0            | 1        | 0     |

# Diagnostics

● Critical   ● Medium   ● Minor / Informative

| Severity | Code  | Description                                | Status   |
|----------|-------|--------------------------------------------|----------|
| ●        | HAWCE | Hardcoded Admin Wallet Credentials Exposed | Resolved |
| ●        | OCI   | Outdated Components Implemented            | Resolved |
| ●        | CHM   | CSP Header Misconfigured                   | Resolved |



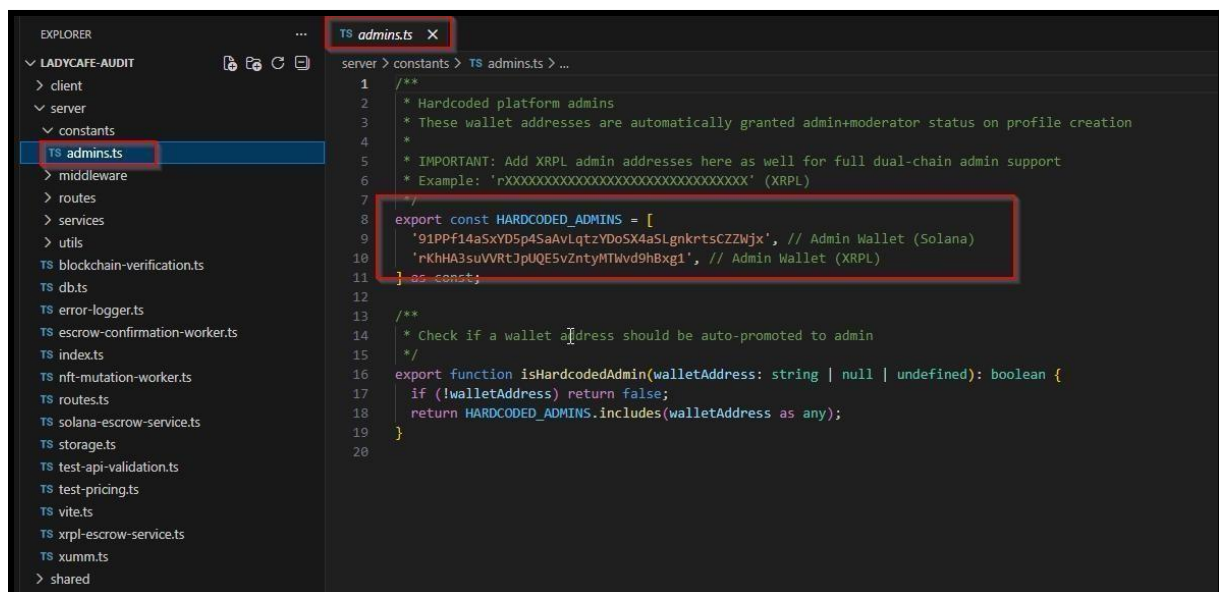
## HAWCE - Hardcoded Admin Wallet Credentials Exposed

|              |          |
|--------------|----------|
| Criticality  | Critical |
| Status       | Resolved |
| CWE ID:      | 1104     |
| CVSS3 Score: | 6.5      |

### Description

The source code contains a hardcoded administrative wallet address associated with XRPL and Solana networks. Embedding sensitive wallet identifiers directly in the codebase exposes critical administrative assets to anyone with access to the source code or compiled artifacts. If this repository is leaked, shared, or reverse-engineered, attackers could identify privileged wallets, enabling targeted attacks such as unauthorized transactions, fund redirection, impersonation, or social engineering. This significantly increases the risk of financial loss, operational disruption, and loss of trust, especially in blockchain-based applications where wallet integrity is paramount.

**Proof of Concept:** The below screenshot depicts that Solana XRPL admin wallet addresses are hardcoded in form.

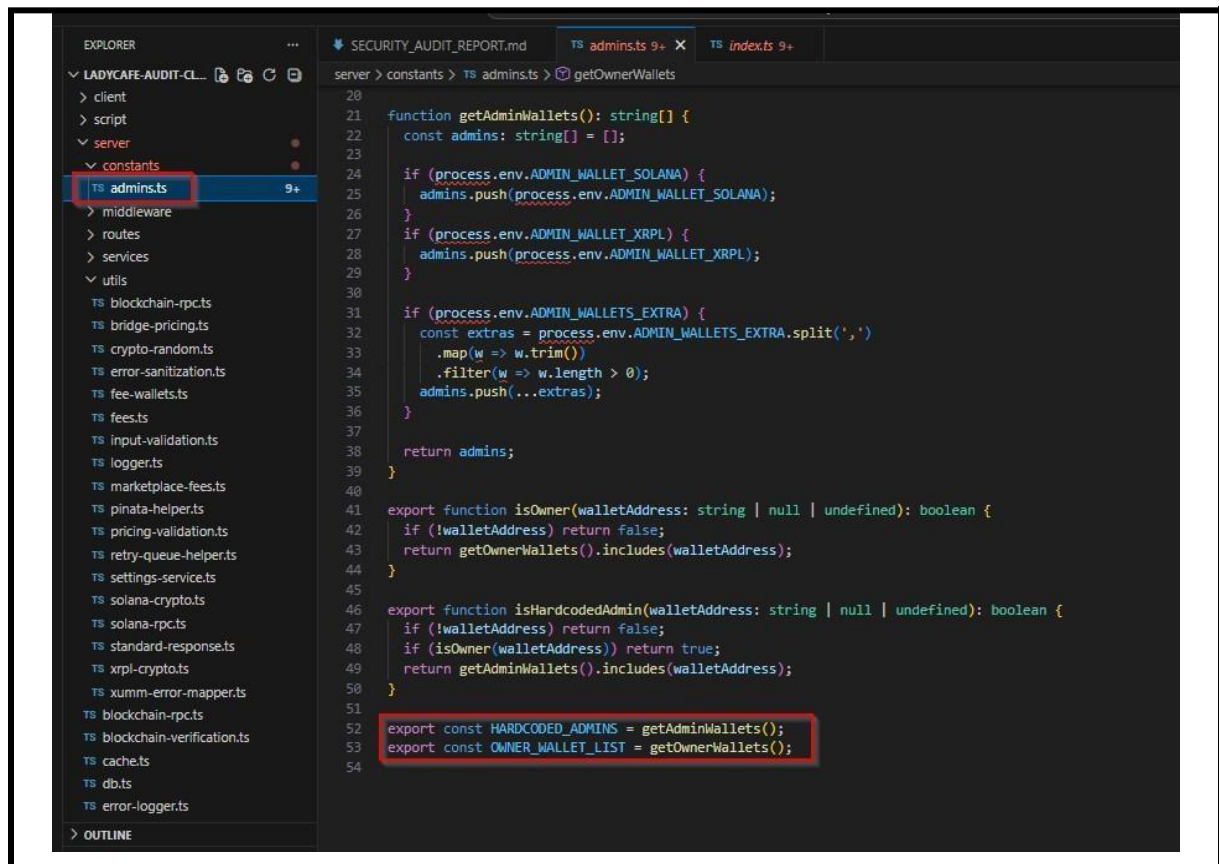


```
1  /**
2   * Hardcoded platform admins
3   * These wallet addresses are automatically granted admin+moderator status on profile creation
4   *
5   * IMPORTANT: Add XRPL admin addresses here as well for full dual-chain admin support
6   * Example: 'rXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXX' (XRPL)
7   */
8   export const HARDCODED_ADMINS = [
9     '91PPf14a5xYD5p4SaAvLqtzYDoSX4aSLgnkrtsCZZWjx', // Admin Wallet (Solana)
10    'rKhHA3suVVRtJpUQE5vZntyMTWvd9hBxg1', // Admin Wallet (XRPL)
11  ] as const;
12
13  /**
14   * Check if a wallet address should be auto-promoted to admin
15   */
16  export function isHardcodedAdmin(walletAddress: string | null | undefined): boolean {
17    if (!walletAddress) return false;
18    return HARDCODED_ADMINS.includes(walletAddress as any);
19  }
20
```

## Recommendation

Remove all hardcoded wallet addresses from the source code immediately. Store sensitive wallet information in secure configuration management systems such as environment variables, secret managers, or hardware security modules (HSMs). Implement role-based access controls and rotate any exposed wallets or keys to mitigate potential compromise. Additionally, conduct a full audit of the codebase to ensure no other sensitive blockchain identifiers or secrets are hardcoded.

**Revalidated Proof of Concept:** The below screenshot depicts that hardcoded wallet addresses have been removed.



```

20
21 function getAdminWallets(): string[] {
22   const admins: string[] = [];
23
24   if (process.env.ADMIN_WALLET_SOLANA) {
25     admins.push(process.env.ADMIN_WALLET_SOLANA);
26   }
27   if (process.env.ADMIN_WALLET_XRPL) {
28     admins.push(process.env.ADMIN_WALLET_XRPL);
29   }
30
31   if (process.env.ADMIN_WALLETS_EXTRA) {
32     const extras = process.env.ADMIN_WALLETS_EXTRA.split(',');
33     .map(w => w.trim())
34     .filter(w => w.length > 0);
35     admins.push(...extras);
36   }
37
38   return admins;
39 }
40
41 export function isOwner(walletAddress: string | null | undefined): boolean {
42   if (!walletAddress) return false;
43   return getOwnerWallets().includes(walletAddress);
44 }
45
46 export function isHardcodedAdmin(walletAddress: string | null | undefined): boolean {
47   if (!walletAddress) return false;
48   if (isOwner(walletAddress)) return true;
49   return getAdminWallets().includes(walletAddress);
50 }
51
52 export const HARDCODED_ADMINS = getAdminWallets();
53 export const OWNER_WALLET_LIST = getOwnerWallets();
54

```

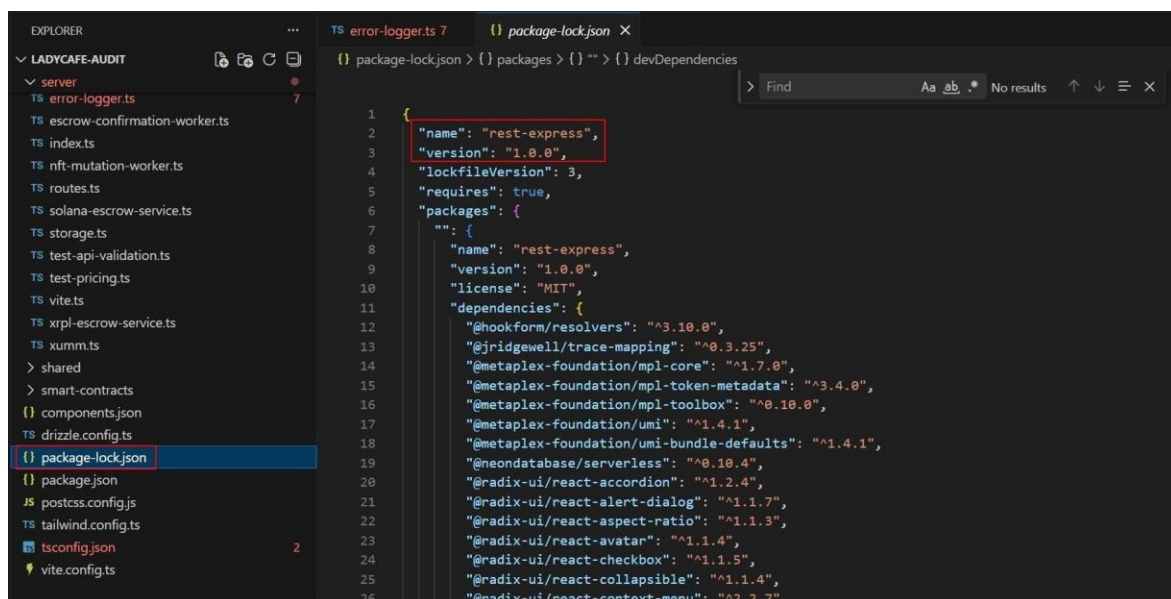
## OCI - Outdated Components Implemented

|              |          |
|--------------|----------|
| Criticality  | Medium   |
| Status       | Resolved |
| CWE ID:      | 1104     |
| CVSS3 Score: | 6.5      |

### Description

The source code review identified the use of outdated third-party components and libraries within the application. These components may contain publicly known vulnerabilities that have been addressed in newer versions but remain unpatched in the current implementation. Exploitation of such vulnerabilities could allow attackers to compromise application security, gain unauthorized access, or cause service disruption. Continued reliance on outdated dependencies increases the attack surface and poses a growing security risk as new exploits are discovered over time.

**Proof of Concept:** The below screenshots depict that outdated components (like express and react) are being used. Those component versions either no longer have any security support or have known vulnerabilities.



The screenshot shows a code editor with the Explorer sidebar on the left and the package-lock.json file open in the main editor. The Explorer sidebar shows a project structure with folders like 'server', 'shared', 'smart-contracts', and 'components.json'. The package-lock.json file is selected and highlighted. The main editor displays the contents of package-lock.json, showing a list of dependencies. The 'name' and 'version' fields for 'rest-express' are highlighted with a red box, showing 'rest-express' version '1.0.0'. Other dependencies listed include 'hookform/resolvers', 'jridgewell/trace-mapping', 'metaplex-foundation/mpl-core', 'metaplex-foundation/mpl-token-metadata', 'metaplex-foundation/mpl-toolbox', 'metaplex-foundation/umi', 'metaplex-foundation/umi-bundle-defaults', 'neondatabase/serverless', 'radix-ui/react-accordion', 'radix-ui/react-alert-dialog', 'radix-ui/react-aspect-ratio', 'radix-ui/react-avatar', 'radix-ui/react-checkbox', 'radix-ui/react-collapsible', and 'radix-ui/react-context-menu'.

```
1 {
2   "name": "rest-express",
3   "version": "1.0.0",
4   "lockfileVersion": 3,
5   "requires": true,
6   "packages": {
7     "": {
8       "name": "rest-express",
9       "version": "1.0.0",
10      "license": "MIT",
11      "dependencies": {
12        "@hookform/resolvers": "^3.10.0",
13        "@jridgewell/trace-mapping": "^0.3.25",
14        "@metaplex-foundation/mpl-core": "^1.7.0",
15        "@metaplex-foundation/mpl-token-metadata": "^3.4.0",
16        "@metaplex-foundation/mpl-toolbox": "^0.10.0",
17        "@metaplex-foundation/umi": "^1.4.1",
18        "@metaplex-foundation/umi-bundle-defaults": "^1.4.1",
19        "@neondatabase/serverless": "^0.10.4",
20        "@radix-ui/react-accordion": "^1.2.4",
21        "@radix-ui/react-alert-dialog": "^1.1.7",
22        "@radix-ui/react-aspect-ratio": "^1.1.3",
23        "@radix-ui/react-avatar": "^1.1.4",
24        "@radix-ui/react-checkbox": "^1.1.5",
25        "@radix-ui/react-collapsible": "^1.1.4",
26        "@radix-ui/react-context-menu": "^2.2.7",
```

**Additional proof of Concept:**

Express

FRAMEWORKHERODEVSJAVASCRIPT-RUNTIMELINUX-FOUNDATION

Last updated on 02 December 2025

ex

Express.js is a minimal and flexible Node.js web application framework used for building web servers and APIs.

| Release | Released                                 | Security Support                    | Commercial Support | Latest                  |
|---------|------------------------------------------|-------------------------------------|--------------------|-------------------------|
| 5       | 1 year and 4 months ago<br>(09 Sep 2024) | Yes                                 | Unavailable        | 5.2.1<br>(01 Dec 2025)  |
| 4       | 11 years ago<br>(09 Apr 2014)            | Yes                                 | Unavailable        | 4.22.1<br>(01 Dec 2025) |
| 3       | 13 years ago<br>(23 Oct 2012)            | Ended 10 years ago<br>(05 Jul 2015) | Yes                | 3.21.2<br>(31 Jul 2015) |
| 2       | 14 years ago<br>(17 Mar 2011)            | Ended 13 years ago<br>(01 Jul 2012) | Unavailable        | 2.5.11<br>(29 Jun 2012) |
| 1       | 15 years ago<br>(16 Nov 2010)            | Ended 14 years ago<br>(01 Mar 2011) | Unavailable        | 1.0.9<br>(23 Mar 2011)  |

## express@1.0.0 vulnerabilities

Fast, unopinionated, minimalist web framework

### Direct Vulnerabilities

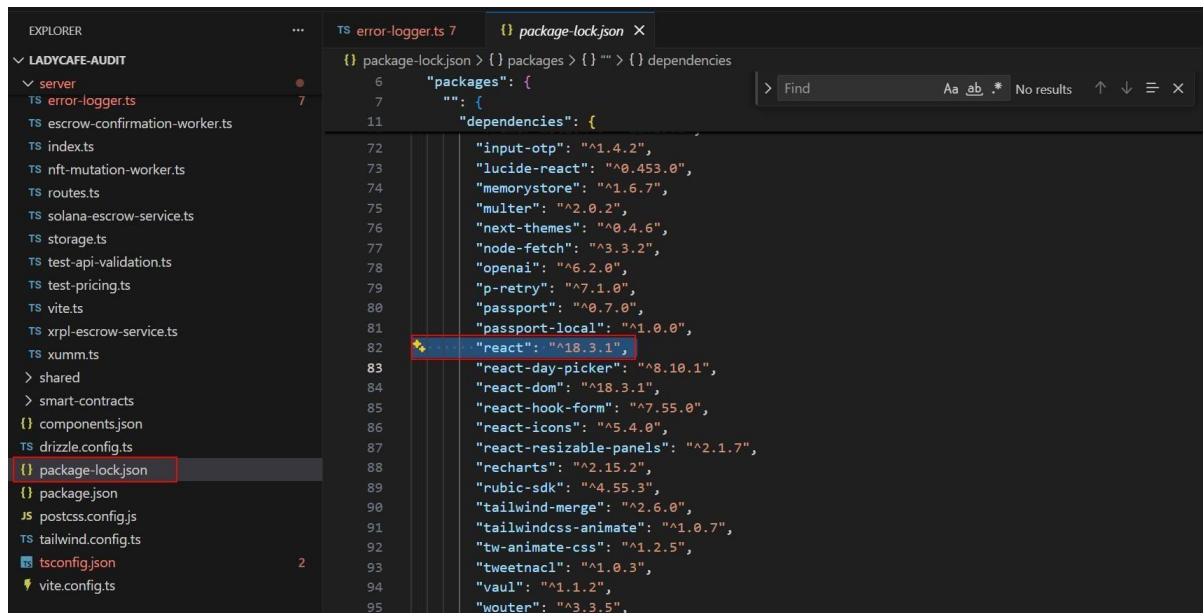
Known vulnerabilities in the express package. This does not include vulnerabilities belonging to this package's dependencies.

#### Fix vulnerabilities automatically

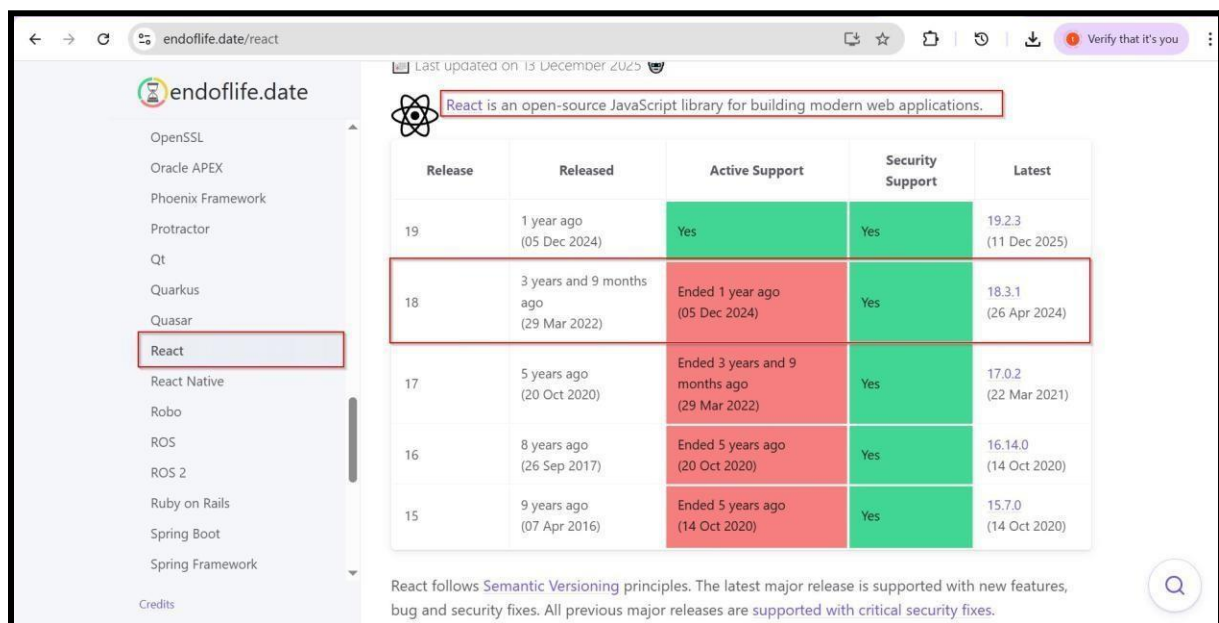
Snyk's AI Trust Platform automatically finds the best upgrade path and integrates with your development workflows. Secure your code at zero cost.

[Fix for free](#)

| Vulnerability                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                | Vulnerable Version   |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------|
| <p><b>M</b> <a href="#">Improper Neutralization of Special Elements in Output Used by a Downstream Component ('Injection')</a></p> <p>express is a minimalist web framework.</p> <p>Affected versions of this package are vulnerable to Improper Neutralization of Special Elements in Output Used by a Downstream Component ('Injection') through the response.links function. An attacker can inject arbitrary resources into the Link header by using unsanitized input that includes special characters such as commas, semicolons, and angle brackets.</p> <p>How to fix Improper Neutralization of Special Elements in Output Used by a Downstream Component ('Injection')?</p> <p>Upgrade express to version 4.0.0-rc1 or higher.</p> | <p>&lt;4.0.0-rc1</p> |
| <p><b>M</b> <a href="#">Cross-site Scripting</a></p> <p>express is a minimalist web framework.</p> <p>Affected versions of this package are vulnerable to Cross-site Scripting due to improper handling of user input in the response.redirect method. An attacker can execute arbitrary code by passing malicious input to this method.</p> <p>Note</p>                                                                                                                                                                                                                                                                                                                                                                                     |                      |



```
6 "packages": {
7   "": {
11    "dependencies": {
12      "input-otp": "^1.4.2",
13      "lucide-react": "^0.453.0",
14      "memorystore": "^1.6.7",
15      "multer": "^2.0.2",
16      "next-themes": "^0.4.6",
17      "node-fetch": "^3.3.2",
18      "openai": "^6.2.0",
19      "p-retry": "^7.1.0",
20      "passport": "^0.7.0",
21      "passport-local": "^1.0.0",
22      "react": "^18.3.1",
23      "react-day-picker": "^8.10.1",
24      "react-dom": "^18.3.1",
25      "react-hook-form": "^7.55.0",
26      "react-icons": "^5.4.0",
27      "react-resizable-panels": "^2.1.7",
28      "recharts": "^2.15.2",
29      "rubic-sdk": "^4.55.3",
30      "tailwind-merge": "^2.6.0",
31      "tailwindcss-animate": "^1.0.7",
32      "tw-animate-css": "^1.2.5",
33      "tweetnacl": "^1.0.3",
34      "vaul": "^1.1.2",
35      "wouter": "^3.3.5",
```



endoflife.date

Last updated on 13 December 2025

React is an open-source JavaScript library for building modern web applications.

| Release | Released                                  | Active Support                                  | Security Support | Latest                   |
|---------|-------------------------------------------|-------------------------------------------------|------------------|--------------------------|
| 19      | 1 year ago<br>(05 Dec 2024)               | Yes                                             | Yes              | 19.2.3<br>(11 Dec 2025)  |
| 18      | 3 years and 9 months ago<br>(29 Mar 2022) | Ended 1 year ago<br>(05 Dec 2024)               | Yes              | 18.3.1<br>(26 Apr 2024)  |
| 17      | 5 years ago<br>(20 Oct 2020)              | Ended 3 years and 9 months ago<br>(29 Mar 2022) | Yes              | 17.0.2<br>(22 Mar 2021)  |
| 16      | 8 years ago<br>(26 Sep 2017)              | Ended 5 years ago<br>(20 Oct 2020)              | Yes              | 16.14.0<br>(14 Oct 2020) |
| 15      | 9 years ago<br>(07 Apr 2016)              | Ended 5 years ago<br>(14 Oct 2020)              | Yes              | 15.7.0<br>(14 Oct 2020)  |

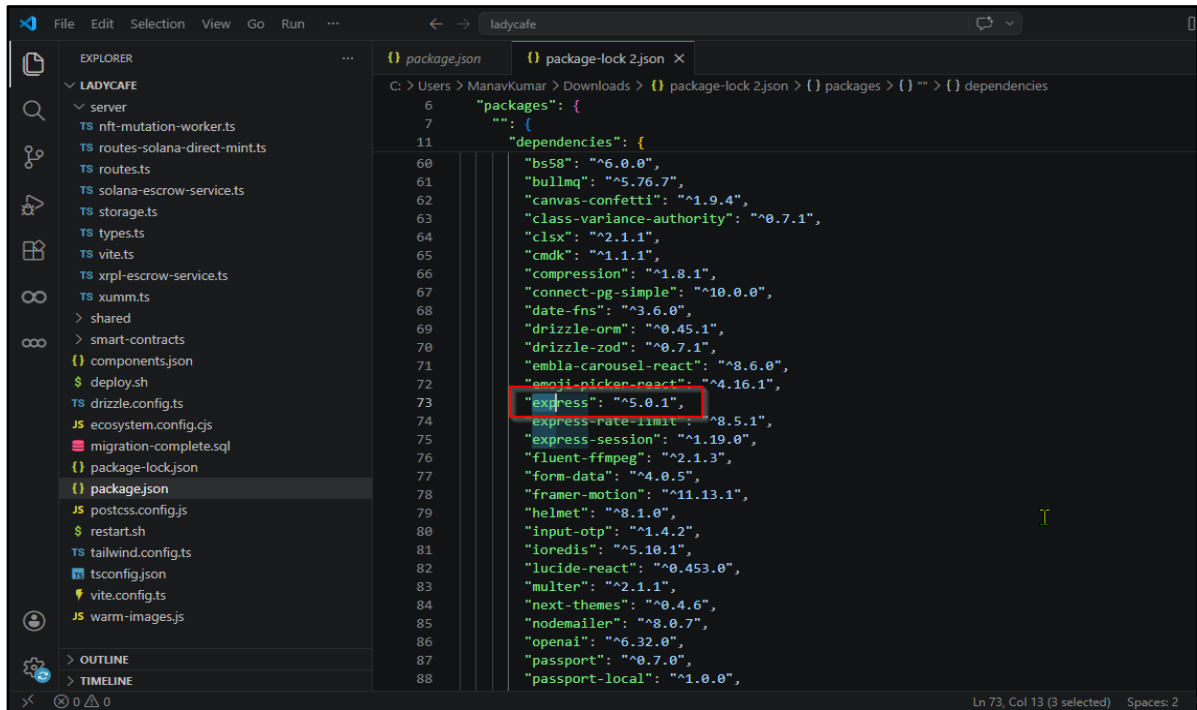
React follows Semantic Versioning principles. The latest major release is supported with new features, bug and security fixes. All previous major releases are supported with critical security fixes.

## Recommendation

Update all outdated components to the latest supported and secure versions. Implement a structured dependency management process, including regular vulnerability scanning, version tracking, and timely patching. Where immediate upgrades are not feasible, apply compensating controls and closely monitor vendor security advisories to mitigate potential risks.



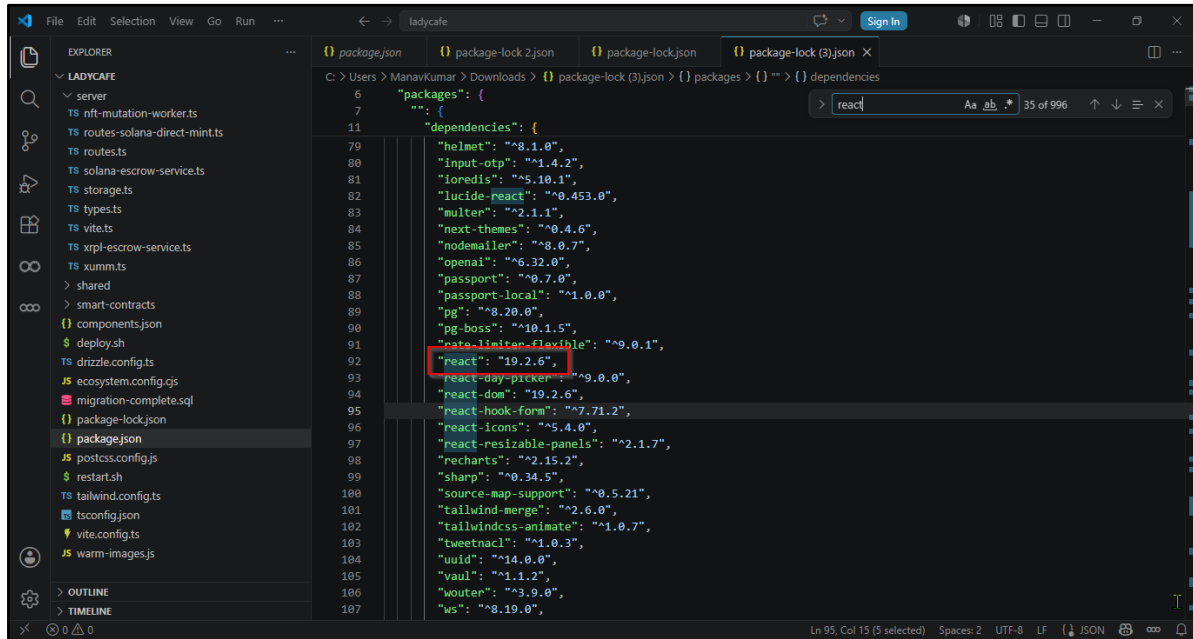
**Revalidated Proof of Concept:** The below screenshots depict that express version 5.0.1 is being used and it has an active security support.



```
6  "packages": {
7    "": {
11     "dependencies": {
60       "bs58": "^6.0.0",
61       "bullmq": "^5.76.7",
62       "canvas-confetti": "^1.9.4",
63       "class-variance-authority": "^0.7.1",
64       "clsx": "^2.1.1",
65       "cmdk": "^1.1.1",
66       "compression": "^1.8.1",
67       "connect-pg-simple": "^10.0.0",
68       "date-fns": "^3.6.0",
69       "drizzle-orm": "^0.45.1",
70       "drizzle-zod": "^0.7.1",
71       "embla-carousel-react": "^8.6.0",
72       "emoji-picker-react": "^4.16.1",
73       "express": ^5.0.1,
74       "express-rate-limit": "^8.5.1",
75       "express-session": "^1.19.0",
76       "fluent-ffmpeg": "^2.1.3",
77       "form-data": "^4.0.5",
78       "framer-motion": "^11.13.1",
79       "helmet": "^8.1.0",
80       "input-otp": "^1.4.2",
81       "ioredis": "^5.10.1",
82       "lucide-react": "^0.453.0",
83       "multer": "^2.1.1",
84       "next-themes": "^0.4.6",
85       "nodemailer": "^8.0.7",
86       "openai": "^6.32.0",
87       "passport": "^0.7.0",
88       "passport-local": "^1.0.0,
```



**Revalidated Proof of Concept:** The below screenshots depict that react version 19.2.6 is being used and it has an active security support.



```
6  "packages": {
7    "": {
8      "dependencies": {
9        "helmet": "^8.1.0",
10       "input-otp": "^1.4.2",
11       "ioredis": "^5.10.1",
12       "lucide-react": "^0.453.0",
13       "multer": "^2.1.1",
14       "next-themes": "^0.4.6",
15       "nodemailer": "^8.0.7",
16       "openai": "^6.32.0",
17       "passport": "^0.7.0",
18       "passport-local": "^1.0.0",
19       "pg": "^8.20.0",
20       "pg-boss": "^10.1.5",
21       "rate-limiter-flexible": "^9.0.1",
22       "react": "19.2.6",
23       "react-day-picker": "^9.0.0",
24       "react-dom": "19.2.6",
25       "react-hook-form": "^7.71.2",
26       "react-icons": "^5.4.0",
27       "react-resizable-panels": "^2.1.7",
28       "recharts": "^2.15.2",
29       "sharp": "^0.34.5",
30       "source-map-support": "^0.5.21",
31       "tailwind-merge": "^2.6.0",
32       "tailwindcss-animate": "^1.0.7",
33       "tweetnacl": "^1.0.3",
34       "uuid": "^14.0.0",
35       "vaul": "^1.1.2",
36       "wouter": "^3.0.0",
37       "ws": "^8.19.0",
38     }
39   }
40 }
```



| Release | Released                                 | Active Support                                  | Security Support | Latest                   |
|---------|------------------------------------------|-------------------------------------------------|------------------|--------------------------|
| 19      | 1 year and 5 months ago<br>(05 Dec 2024) | Yes                                             | Yes              | 19.2.6<br>(06 May 2026)  |
| 18      | 4 years ago<br>(29 Mar 2022)             | Ended 1 year and 5 months ago<br>(05 Dec 2024)  | Yes              | 18.3.1<br>(26 Apr 2024)  |
| 17      | 5 years ago<br>(20 Oct 2020)             | Ended 4 years ago<br>(29 Mar 2022)              | Yes              | 17.0.2<br>(22 Mar 2021)  |
| 16      | 8 years ago<br>(26 Sep 2017)             | Ended 5 years ago<br>(20 Oct 2020)              | Yes              | 16.14.0<br>(14 Oct 2020) |
| 15      | 10 years ago<br>(07 Apr 2016)            | Ended 5 years and 7 months ago<br>(14 Oct 2020) | Yes              | 15.7.0<br>(14 Oct 2020)  |

React follows [Semantic Versioning](#) principles. The latest major release is supported with new features, bug and security fixes. All previous major releases are [supported with critical security fixes](#).



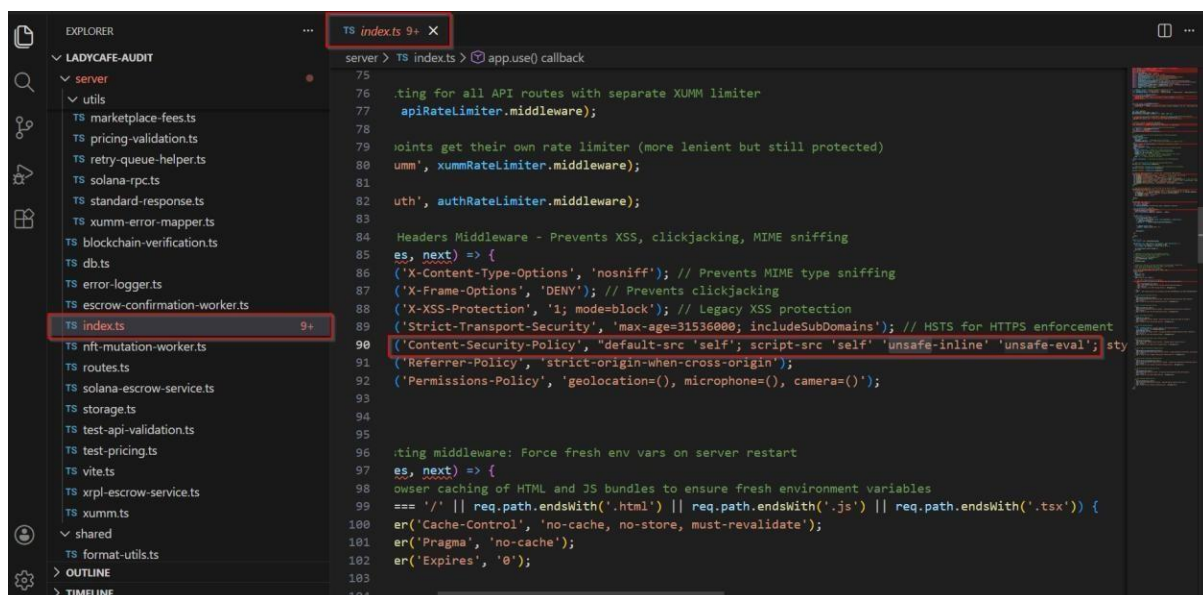
## CHM - CSP Header Misconfigured

|              |                     |
|--------------|---------------------|
| Criticality  | Minor / Informative |
| Status       | Resolved            |
| CWE ID:      | 693                 |
| CVSS3 Score: | 3.1                 |

### Description

The application's Content Security Policy (CSP) header is configured with `unsafe-inline` and `unsafe-eval` directives. These settings weaken the browser's built-in defenses against client-side attacks, particularly Cross-Site Scripting (XSS). While no immediate exploitation was observed during the review, the presence of these directives allows the execution of inline scripts and dynamic code evaluation, increasing the attack surface. If combined with another vulnerability, this misconfiguration could facilitate malicious script execution in users' browsers.

**Proof of Concept:** The below screenshot depicts that the CSP header is misconfigured since `'unsafe-inline'` and `'unsafe-eval'` is set among the header values.



The screenshot shows a code editor with a file named `TS index.ts` open. The file contains a function `es, next => {` that sets various HTTP headers. The CSP header is configured as follows:

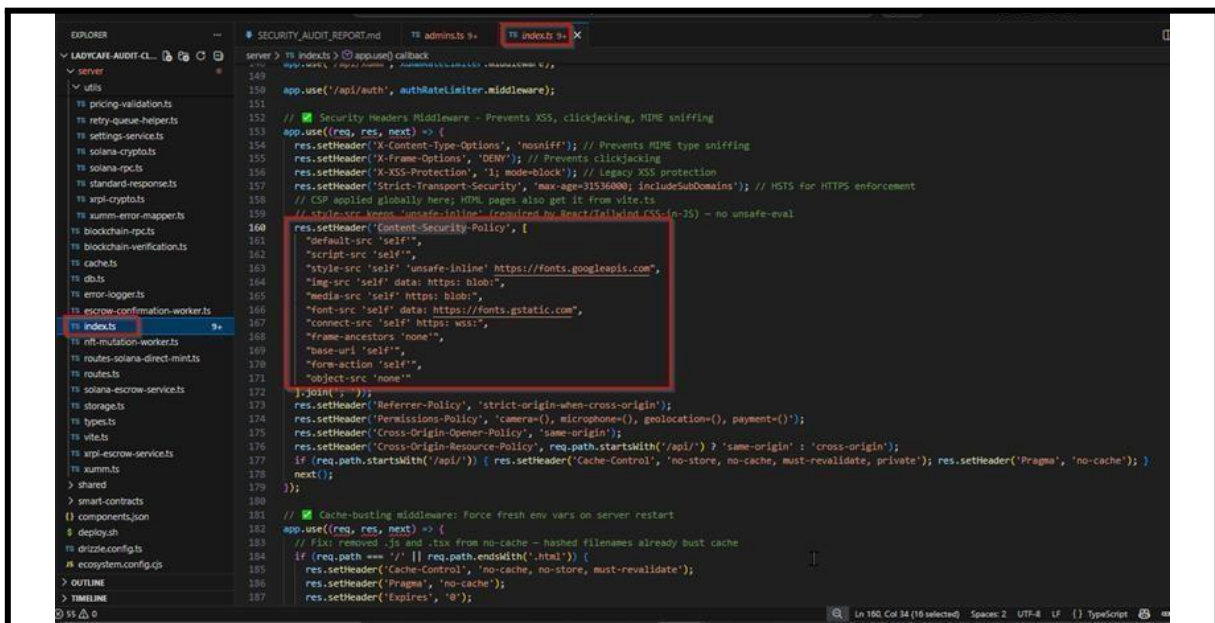
```
90 ('Content-Security-Policy', 'default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval'; style-src 'self' 'unsafe-inline';
```

The `'unsafe-inline'` and `'unsafe-eval'` directives are highlighted with a red box, indicating the misconfiguration. The file explorer on the left shows the project structure, with `TS index.ts` selected.

## Recommendation

Remove unsafe-inline and unsafe-eval directives from the CSP wherever possible. Refactor inline scripts into external files and use nonces or hashes for necessary dynamic content. Enforce a strict CSP policy aligned with security best practices to reduce the likelihood of client-side attacks.

**Revalidated Proof of Concept:** The below screenshot depicts that the CSP header is configured properly.



```
server > TI index.js > app.use() callback
149
150 app.use('/api/auth', authRateLimiter.middleware);
151
152 // Security Headers Middleware - Prevents XSS, clickjacking, MIME sniffing
153 app.use((req, res, next) => {
154   res.setHeader('X-Content-Type-Options', 'nosniff'); // Prevents MIME type sniffing
155   res.setHeader('X-Frame-Options', 'DENY'); // Prevents clickjacking
156   res.setHeader('X-XSS-Protection', '1; mode=block'); // Legacy XSS protection
157   res.setHeader('Strict-Transport-Security', 'max-age=31536000; includeSubDomains'); // HSTS for HTTPS enforcement
158   // CSP applied globally here; HTML pages also get it from vite.ts
159   // style-src 'self' 'unsafe-inline' 'unsafe-eval' 'unsafe-eval' 'unsafe-eval' 'unsafe-eval' 'unsafe-eval' 'unsafe-eval' - no unsafe-eval
160   res.setHeader('Content-Security-Policy', [
161     "default-src 'self'",
162     "script-src 'self'",
163     "style-src 'self' 'unsafe-inline' https://fonts.googleapis.com",
164     "img-src 'self' data: https://blobs",
165     "media-src 'self' https://blobs",
166     "font-src 'self' data: https://fonts.gstatic.com",
167     "connect-src 'self' https://wsn",
168     "frame-ancestors 'none'",
169     "base-uri 'self'",
170     "form-action 'self'",
171     "object-src 'none'"
172   ].join('; '));
173   res.setHeader('Referrer-Policy', 'strict-origin-when-cross-origin');
174   res.setHeader('Permissions-Policy', 'camera=(), microphone=(), geolocation=(), payment=()');
175   res.setHeader('Cross-Origin-Opener-Policy', 'same-origin');
176   res.setHeader('Cross-Origin-Resource-Policy', req.path.startsWith('/api/') ? 'same-origin' : 'cross-origin');
177   if (req.path.startsWith('/api/')) { res.setHeader('Cache-Control', 'no-store, no-cache, must-revalidate, private'); res.setHeader('Pragma', 'no-cache'); }
178   next();
179 });
180
181 // Cache-busting middleware: Force fresh env vars on server restart
182 app.use((req, res, next) => {
183   // Fix: removed .js and .tsx from no-cache - hashed filenames already bust cache
184   if (req.path === '/' || req.path.endsWith('.html')) {
185     res.setHeader('Cache-Control', 'no-cache, no-store, must-revalidate');
186     res.setHeader('Pragma', 'no-cache');
187     res.setHeader('Expires', '0');
```

## Summary

The source code review identified three security findings with varying levels of risk. A critical issue was observed in the form of a hardcoded administrative wallet for XRPL and Solana, which poses a significant risk of financial loss and unauthorized access if exposed or misused. Additionally, a medium-severity issue related to the use of outdated third-party components increases the application's attack surface and may allow exploitation of known vulnerabilities over time. Lastly, a low-severity misconfiguration in the Content Security Policy (CSP) header was identified, which weakens client-side security controls and could facilitate browser-based attacks if combined with other vulnerabilities.

Overall, while some findings are configuration- and maintenance-related, the presence of a critical hardcoded wallet highlights the need for immediate remediation. Addressing these issues through secure secret management, regular dependency updates, and stronger security configurations will significantly enhance the application's security posture and reduce the risk of future compromise.

## Disclaimer

The information provided in this report does not constitute investment, financial or trading advice and you should not treat any of the document's content as such. This report may not be transmitted, disclosed, referred to or relied upon by any person for any purposes nor may copies be delivered to any other person other than the Company without Cyberscope's prior written consent. This report is not nor should be considered an "endorsement" or "disapproval" of any particular project or team. This report is not nor should be regarded as an indication of the economics or value of any "product" or "asset" created by any team or project that contracts Cyberscope to perform a security assessment. This document does not provide any warranty or guarantee regarding the absolute bug-free nature of the technology analyzed, nor do they provide any indication of the technologies proprietors' business, business model or legal compliance. This report should not be used in any way to make decisions around investment or involvement with any particular project. This report represents an extensive assessment process intending to help our customers increase the quality of their code while reducing the high level of risk presented by cryptographic tokens and blockchain technology.

Blockchain technology and cryptographic assets present a high level of ongoing risk. Cyberscope's position is that each company and individual are responsible for their own due diligence and continuous security. Cyberscope's goal is to help reduce the attack vectors and the high level of variance associated with utilizing new and consistently changing technologies and in no way claims any guarantee of security or functionality of the technology we agree to analyze. The assessment services provided by Cyberscope are subject to dependencies and are under continuing development. You agree that your access and/or use including but not limited to any services reports and materials will be at your sole risk on an as-is where-is and as-available basis. Cryptographic tokens are emergent technologies and carry with them high levels of technical risk and uncertainty. The assessment reports could include false positives, false negatives and other unpredictable results. The services may access and depend upon multiple layers of third parties.

# About Cyberscope

Cyberscope is a TAC blockchain cybersecurity company that was founded with the vision to make web3.0 a safer place for investors and developers. Since its launch, it has worked with thousands of projects and is estimated to have secured tens of millions of investors' funds.

Cyberscope is one of the leading smart contract audit firms in the crypto space and has built a high-profile network of clients and partners.



A **TAC Security** Company

**The Cyberscope team**

[cyberscope.io](https://cyberscope.io)